Compliance and Secure Coding Practices

MediRecon

Hybrid AI-based Detection of Fileless Malware in IoMT Healthcare Systems

Final research project submission.

Project details

Project ID: R26-CS-006

Institution: Sri Lanka Institute of Information Technology

Department: Computer Systems & Engineering

Programme: BSc (Hons) Information Technology, Cyber Security

Supervisor: Mr. Kanishka Yapa

Co-supervisor: Mr. Dinith Primal

Submission date: 14 October 2026

Student details

Student name	Student ID	Component responsibility
Chathuranga L. A. S.	IT22108272	DICOM network anomaly detection and integrity checking
M. S. V. Fernando	IT22080530	PowerShell fileless-malware detection
Pagodaarachchi R. T.	IT22135070	Predictive IoMT threat forecasting
Shakya W. A. R.	IT22210142	Cross-layer correlation and XAI dashboard

This report covers the four-component research implementation, secure development evidence, relevant compliance considerations, and outstanding final acceptance checks. The assessment concerns a controlled research environment.

1 Introduction

MediRecon addresses the difficulty of connecting fileless-malware indicators across healthcare IoMT networks and endpoints. It combines DICOM network anomaly detection, PowerShell analysis, next-24-hour threat forecasting, and cross-layer incident correlation. The system provides SOC-facing evidence and a DICOM integrity workflow linking original and received studies. Its objective is to support investigation through connected observations rather than treat each alert as an isolated event [1,3,4].

Secure development is essential because medical-image uploads, endpoint scripts, network telemetry, model files, APIs, and reporting interfaces cross trust boundaries. This final report records implemented safeguards and completed laboratory work, while separating functional results from security assurance. Source documents include the project checklist, individual theses, and development history. The example drone-forensics report informs organisation only; its controls and test results are not evidence for MediRecon [1,2].

2 Secure Coding Standards

2.1 OWASP guidance

OWASP provides the review basis for input validation, safe database access, error handling, output encoding, and access control [5]. Relevant MediRecon interfaces include DICOM uploads, PowerShell text, telemetry JSON, stored events, and dashboard fields. Demonstrated controls include selected guards and parameterized database writes. Full OWASP checklist conformance is not asserted. The archived Quick Reference Guide now directs readers to the Developer Guide.

2.2 Secure development and information security

NIST SSDF provides a reference for integrating security into development and addressing software vulnerabilities [6]. MediRecon development included iterative corrections, selected source checks, and controlled tests. A complete SSDF assessment, protected-repository audit, and release security-scan pack remain unverified. ISO/IEC 27001 supplies the information-security management context for risk assessment and accountability; the prototype does not establish a certified ISMS [7].

2.3 Assessment scope and terminology

Completed denotes delivered functionality supported by implementation or recorded operation. Reported complete identifies a team or thesis result whose underlying test artifact still needs inclusion. Partial means that only part of the control or its verification is established. Pending verification means the evidence is insufficient for acceptance; it does not automatically mean the feature is absent. None of these statuses represents independent certification.

The final C2 pipeline uses TF-IDF/XGBoost and behavioural indicators, without LSTM. C3 retains a separate single-LSTM forecasting design. These changes are reflected throughout the report; older hybrid-model metrics are not treated as current C2 release results [3,4].

3 Key Secure Coding Techniques Implemented

3.1 DICOM capture guards and feature consistency

C1 was exercised using Orthanc and a second laptop sending C-ECHO and C-STORE traffic over Wi-Fi. TShark capture feeds 28 live features to Random Forest inference and database/SOC storage. Central configuration, an insufficient-packet guard, and duplicate-alert suppression were added during development. These checks reduce invalid inference attempts and repeated presentation of the same observation [1,3].

The DICOM-to-TCP mapping and PSH counting were corrected after inspection of captured traffic. One recorded run processed 138 packets with a TCP ratio of 0.9928 and 16 PSH packets. This demonstrates processing behaviour, not labelled attack-detection accuracy. The release must preserve the fitted feature order, units, duration calculation, and preprocessing so that valid-looking values do not enter the wrong model columns.

3.2 Cryptographic integrity checking

The C1 integrity workflow computes SHA-256 over DICOM file bytes. The SOC registers a trusted original digest; the doctor portal compares a received-file digest with that reference and requires a non-empty original hash. Results and mismatch alerts are saved through the database layer. Separate original and received locations support the workflow, but protected originals and overwrite prevention still require acceptance evidence [1].

A matching digest establishes byte equality with the chosen reference. A mismatch establishes byte inequality and requires investigation; legitimate DICOM rewriting can also alter bytes. Hashing does not encrypt the study, authenticate its source, or establish clinical safety. These boundaries matter when interpreting VERIFIED or TAMPERED interface labels.

3.3 Parameterized persistence

The reviewed C1 study and alert database operations bind values as SQL parameters rather than building statements from untrusted text. This reduces SQL-injection exposure in those operations. It does not prove that every query is safe or that the database is encrypted or immutable. Event identity, protected storage, backup restoration, and administrative permissions remain separate review points [1].

3.4 Safe PowerShell analysis

C2 extracts script content from PowerShell Operational events, including 4103 and 4104, and applies text classification with behavioural indicators such as encoded commands, Invoke-Expression, download activity, and hidden execution. Script content is intended to be analysed as data. Final negative tests must establish that inference and upload paths never execute submitted content, including malformed or adversarial strings [1,4].

Model probability and behaviour-adjusted risk must remain distinguishable in stored results. The deployment package should contain the current XGBoost model and matching text preprocessing artifacts, with obsolete C2 LSTM dependencies removed. Checksums and restricted modification of these files remain release-verification requirements.

3 Key Secure Coding Techniques Continued

3.5 Temporal input handling and forecasting

C3 uses a single LSTM to classify next-24-hour IoMT risk as LOW, MEDIUM, HIGH, or CRITICAL. It replaces the PPR Random Forest baseline. The documented input consists of 28 telemetry features arranged as twelve consecutive five-minute windows. The team identifies the downloaded research dataset as IoMT-Risk-Prediction-Datase 2026; source, licence, revision, and checksum records must be retained with the research evidence [3,4].

Live collection, LSTM integration, forecast history, SOC reporting, and automated notifications have been implemented and exercised in the controlled test environment. The final team update records completion on the C1 PC and reports chronological evaluation complete. A WINDOW_AVAILABLE response establishes that a feature window is available; predictive accuracy must instead be supported by the chronological evaluation outputs.

Final review must reconcile the exact target-generation rule, split dates, sequence length, train-only preprocessing, and missing-telemetry policy with the model used in the integration test. Input-window overlap and future target horizons must not carry information across evaluation boundaries. Missing observations must not silently become evidence of zero activity. No unsupported final LSTM accuracy or forecasting-performance value is asserted.

3.6 Traceable correlation and explanations

C4 normalizes available component events, combines graph and temporal relationships with model or contextual evidence, and stores scored incidents for the dashboard. The development record includes a combined CRITICAL incident with risk 0.9622. That value is an incident score, not a detection-accuracy measurement. Source component, event time, and contributing evidence must remain inspectable after fusion [1,3,4].

SHAP, LIME, and MITRE-mapping modules form part of the implementation. Where compatible model inference has not run, the interface should present the actual correlation signals and explicitly identify unavailable model explanations. The current acceptance task is to follow genuine explanation fields from ingestion through fusion and storage to rendering. A rule score or demonstration explanation cannot establish live model attribution.

3.7 Credentials and failure visibility

The C3 thesis documents SMTP credentials configured outside source code. Forecast records and SOC reports retain operational context, and the supplied thesis includes notification-delivery evidence. Email failure, unavailable telemetry, and incomplete sequence history should remain distinguishable from successful processing. End-to-end failure handling and log redaction still require release checks [4].

Role-specific SOC and doctor screens are implemented, but screens alone do not establish authentication or authorization. Controlled HTTP connectivity also does not establish TLS protection. These controls remain explicit verification items rather than inferred benefits of the selected frameworks.

4 Tools and Technologies Used for Secure Coding

4.1 Implementation and verification tools

Tool or platform	Documented role	Verification boundary
Python and ML libraries	RF in C1; TF-IDF/XGBoost in C2; TensorFlow/Keras LSTM in C3.	Exact package/model versions belong in the release manifest.
Orthanc, TShark, pydicom	DICOM exchange, traffic inspection, file metadata and integrity workflow.	Successful parsing does not prove safe handling of all uploads.
Windows PowerShell logs	Endpoint event and script-text collection for C2.	Classifier input must remain data rather than executable code.
FastAPI and SQLite	Component interfaces and persistent events, windows, forecasts and incidents.	Framework choice does not establish access control or storage encryption.
Streamlit and reporting modules	SOC and doctor views, forecast history, PDF reports and notifications.	Rendering, privacy, recipient configuration and failure paths need review.
Compilation and database checks	Selected py_compile checks; C4 source parsing and database assertions.	Functional checks do not replace static security or penetration testing.

4.2 Code review and audit process

Recorded reviews examined C1 mapping and packet guards, C2 model changes, C3 telemetry readiness, and C4 explanation persistence. Fixes were checked through compilation, API responses, captures, database records, and dashboard output. The C4 thesis reports 33 Python files parsed and 20 database assertions passed across nine sections; an archived integration test nevertheless failed because an incident appeared earlier than expected [3,4].

A final review should preserve each defect, affected source revision, corrective change, repeat-test result, and unresolved limitation. Compilation confirms syntax only. Assertions against isolated database behaviour cannot prove that all four live delivery paths are reliable during concurrent operation.

4.3 Security tooling and supply chain

No retained MediRecon Bandit, pip-audit, SonarQube, ZAP, Burp Suite, or coverage report establishes a completed release assessment. These are possible final-review tools, not claimed project achievements. The release should identify dependency versions, model/scaler files, trusted origins, and digests; findings should be reviewed rather than equating a scan invocation with a pass.

5 Compliance Standards and Ethical Considerations

5.1 Information security and healthcare safeguards

ISO/IEC 27001 provides the management-system reference for protecting information and evaluating risk [7]. MediRecon contributes selected technical capabilities, including anomaly monitoring, evidence persistence, and DICOM integrity comparison. These capabilities do not establish organization-wide governance, a certified ISMS, or an independent compliance audit.

HIPAA provides a relevant healthcare safeguard reference, but its applicability depends on the entity and handling of electronic protected health information [8]. A healthcare-themed prototype is not automatically a HIPAA-regulated deployment. The research does not claim HIPAA or GDPR compliance. A real deployment would need a separate assessment of applicable Sri Lankan and other jurisdictional data-protection obligations, contracts, and institutional requirements.

5.2 Personal data and authorized collection

DICOM metadata can include patient names and identifiers, while endpoint telemetry can contain usernames, hostnames, paths, and sensitive command content. Demonstrations and published evidence should use verified sample or de-identified studies and redact operational identifiers. The documented environment is a controlled laboratory; no live-hospital deployment or clinical safety approval is established [1,4].

Collection scope should be limited to authorized devices and required fields. Access, retention, deletion, report sharing, and any required participant consent or ethics approval need documented owners and procedures. Configuring separate dashboards does not itself enforce these obligations. De-identification and access-control tests remain part of the final privacy review.

5.3 Dataset and model accountability

The final submission should retain dataset acquisition records, licence terms, checksums, preprocessing versions, and model-to-evaluation linkage. For C3, the downloaded dataset name is recorded from the team’s update; the original publisher and repository citation still need confirmation. Acquisition location does not by itself establish how a dataset was originally produced. Chronological evaluation results and integration records should be submitted together [3,4].

The C2 thesis reports XGBoost evaluation separately from earlier hybrid experiments. C4 historical network-classifier metrics are not measurements of the entire incident-correlation engine. Reports must preserve the unit of evaluation and avoid presenting inference confidence, incident severity, or successful API delivery as model accuracy.

5.4 Responsible interpretation and response

MediRecon supports analyst decision-making. An anomaly is not proof of malicious activity, a future-risk forecast is not an observed compromise, and a DICOM hash match is not diagnostic validation. SOC notifications and recommended actions are implemented decision-support outputs. Automatic isolation of clinical devices is outside the accepted baseline scope and would require separate authorization and safety assessment [1,4].

6 Challenges and Mitigation Strategies

6.1 Limited resources and changing network configuration

The integration testbed used two laptops and Orthanc to fit available hardware resources. Central configuration reduced scattered address changes, while C-ECHO and C-STORE tests established connectivity before capture and inference checks. Final evidence should identify machine roles, addresses at test time, capture interfaces, and service endpoints. These laboratory runs cannot establish performance across an operational hospital network [3].

6.2 Training and live telemetry differences

C1's recorded training context and live 28-feature representation are not interchangeable without a documented transformation or separately fitted model. TCP/PSH mapping was corrected, but feature order, units, timestamp-derived rates, and distribution differences remain release-review concerns. Benign DICOM traffic classified as abnormal needs false-positive investigation rather than being counted as a confirmed attack.

6.3 Forecast evaluation and operating stability

C3's LSTM integration, live forecasting, and SOC reporting have been completed in the C1 PC test environment, with chronological evaluation reported complete. The remaining review concerns the evaluation artifact and operating stability: exact split boundaries, future-label alignment, preprocessing isolation, missing observations, network variation, and increased telemetry loads. The test pack should include metrics, predictions, live forecasting records, and SOC reports tied to the same model version [3,4].

6.4 Correlation timing and explanation availability

C4's archived staged test produced a final incident earlier than expected. The cause must be assessed against the intended correlation timing and expected outcomes before a full-system pass is recorded. Explanation debugging also requires separate checks for inference execution, fusion retention, database storage, and dashboard rendering. A correlation-only incident should expose observed evidence even when model explanations are unavailable.

6.5 Shared interfaces and data protection

The existing API and dashboard interfaces enable collaboration between components, but they also expose trust boundaries. Final review should cover unauthorized requests, role restrictions, malicious filenames, malformed DICOM structures, oversized payloads, HTML-enabled output, and transport protection. A .dcm extension filter or a permissive parser is insufficient evidence of safe upload validation [1].

6.6 Closing the release review

Freeze the submitted source and model artifacts, retain test environments and timestamps, and run a synchronized scenario trace from source events to stored incidents and dashboard output. Include benign traffic, a controlled suspicious endpoint event, an integrity mismatch, a forecast, and a correlation-only incident. Record failures and incomplete coverage explicitly. This makes the final submission reproducible without overstating the scope of completed testing.

7 Summary of Implementation and Verification

7.1 Final component status

Part	Completed work	Remaining verification
C1	DICOM exchanges; live capture, feature extraction, RF inference and persistence; mapping guards; integrity workflow implementation.	Final live-model schema linkage, benign false-positive review, and matching/mismatching/absent-original integrity tests.
C2	TF-IDF/XGBoost classifier, behavioural indicators, endpoint/API connectivity, and thesis-reported classifier evaluation.	Current release-to-evaluation linkage, safe handling of script input, false-positive review, and continuous delivery to C4.
C3	Single-LSTM integration, live forecasting, 28-feature telemetry, forecast history, SOC reports and automated alerts. Chronological evaluation reported complete.	Attach evaluation results and split records; verify missing telemetry, forecast stability, load handling, and exact dataset citation.
C4	Event normalization, correlation, risk fusion, persistence and dashboard implementation; reported source/database checks.	Resolve staged-test failure; verify continuous component delivery and genuine live SHAP/LIME storage and display.

7.2 Recorded evaluation and interpretation

The C2 thesis reports XGBoost accuracy of 97.16%, precision of 97.16%, recall of 98.56%, and F1 of 97.86%. These are thesis-reported classifier results, not a rerun of the final deployed behavioural pipeline. The earlier XGBoost–LSTM hybrid results remain historical and are not relabelled as current C2 performance [4].

For C1, successful capture and inference demonstrate execution. Displayed abnormal-class probabilities do not substitute for labelled held-out detection metrics. For C3, completed operational forecasting and notification delivery are distinct from the still-to-be-attached chronological evaluation results. No final LSTM metric is invented. For C4, database assertions and an incident score are not incident-level precision or recall [3,4].

7.3 Integrated acceptance status

Component implementation is substantially complete, while acceptance of the complete integrated system remains conditional on the identified evidence and security checks. Continuous C2/C3 forwarding, synchronized regression, and explanation persistence require a repeatable release-specific trace. No overall compliance percentage or averaged model accuracy is calculated, because the components perform different tasks and use different evaluation units.

7 Summary of Secure Coding Controls Continued

7.4 Control assessment matrix

Control	Status	Assessment and close-out evidence
Input and upload validation	Partial	Packet and sequence guards exist. Verify server-side type, size, structure and malformed-input rejection.
Upload path containment	Pending verification	Confirm filename sanitization, resolved-path containment and overwrite prevention.
Authentication and roles	Pending verification	SOC/doctor views do not establish enforced identities or permissions; retain unauthorized-access tests.
Transport and storage protection	Pending verification	Recorded HTTP connectivity is not TLS. Retain protected-channel and storage configuration checks.
Integrity and model trust	Partial	DICOM SHA-256 comparison exists. Authenticate reference hashes and protect model/preprocessing artifacts.
Database and audit records	Partial	Selected writes use parameters; events and outputs persist. Audit immutability and full query coverage are unverified.
Output and error handling	Partial	Check HTML-enabled fields, safe error responses, redaction, and explicit failed-operation states.
Privacy and retention	Partial	Test de-identification, access restrictions, publication redaction, retention and deletion procedures.
Static and dependency analysis	Pending verification	Retain release-specific scan results and disposition of findings; no scan pass is currently claimed.
Availability and recovery	Partial	Deduplication and readiness guards exist. Test load, retries, outages, restart recovery and backup restoration.

7.5 Evidence pack and assessment conclusion

The final evidence pack should link the source revision, dataset identifiers, model/scaler versions, feature schemas, thresholds, test inputs, API responses, database records, and dashboard/report outputs. C3 chronological results and SOC reports should accompany the C1 PC integration records. Record who reviewed each item and preserve unresolved findings rather than signing off without results.

MediRecon has progressed from the PPR design to implemented detection, forecasting, integrity, and correlation workflows demonstrated in a controlled environment. The remaining work concerns specific security controls, release verification, and broader robustness. The report documents that final-stage position without claiming hospital readiness, clinical certification, or independently audited regulatory compliance.

8 References

[1] Y. Sun, F. P.-W. Lo, and B. Lo, “Security and Privacy for the Internet of Medical Things Enabled Healthcare Systems: A Survey,” IEEE Access, vol. 7, pp. 183339–183355, 2019. doi: 10.1109/ACCESS.2019.2960617. https://ieeexplore.ieee.org/document/8936335

[2] J. H. Saltzer and M. D. Schroeder, “The Protection of Information in Computer Systems,” Proceedings of the IEEE, vol. 63, no. 9, pp. 1278–1308, 1975. doi: 10.1109/PROC.1975.9939. https://ieeexplore.ieee.org/document/1451869

[3] L. Breiman, “Random Forests,” Machine Learning, vol. 45, pp. 5–32, 2001. doi: 10.1023/A:1010933404324. https://doi.org/10.1023/A:1010933404324

[4] T. Chen and C. Guestrin, “XGBoost: A Scalable Tree Boosting System,” in Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining, 2016, pp. 785–794. doi: 10.1145/2939672.2939785. https://dl.acm.org/doi/10.1145/2939672.2939785

[5] S. Hochreiter and J. Schmidhuber, “Long Short-Term Memory,” Neural Computation, vol. 9, no. 8, pp. 1735–1780, 1997. doi: 10.1162/neco.1997.9.8.1735. https://doi.org/10.1162/neco.1997.9.8.1735

[6] S. Kapoor and A. Narayanan, “Leakage and the Reproducibility Crisis in Machine-Learning-Based Science,” Patterns, vol. 4, no. 9, article 100804, 2023. doi: 10.1016/j.patter.2023.100804. https://doi.org/10.1016/j.patter.2023.100804

[7] S. M. Lundberg and S.-I. Lee, “A Unified Approach to Interpreting Model Predictions,” in Advances in Neural Information Processing Systems, vol. 30, 2017. https://proceedings.neurips.cc/paper_files/paper/2017/hash/8a20a8621978632d76c43dfd28b67767-Abstract.html

[8] M. T. Ribeiro, S. Singh, and C. Guestrin, “Why Should I Trust You?: Explaining the Predictions of Any Classifier,” in Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining, 2016, pp. 1135–1144. doi: 10.1145/2939672.2939778. https://dl.acm.org/doi/10.1145/2939672.2939778